BBVA
API Market

Technical Documentation

BBVA, best bank with financial solutions via APIs for companies in 2024

API Connect two-legged OAuth v2.5

Authentication

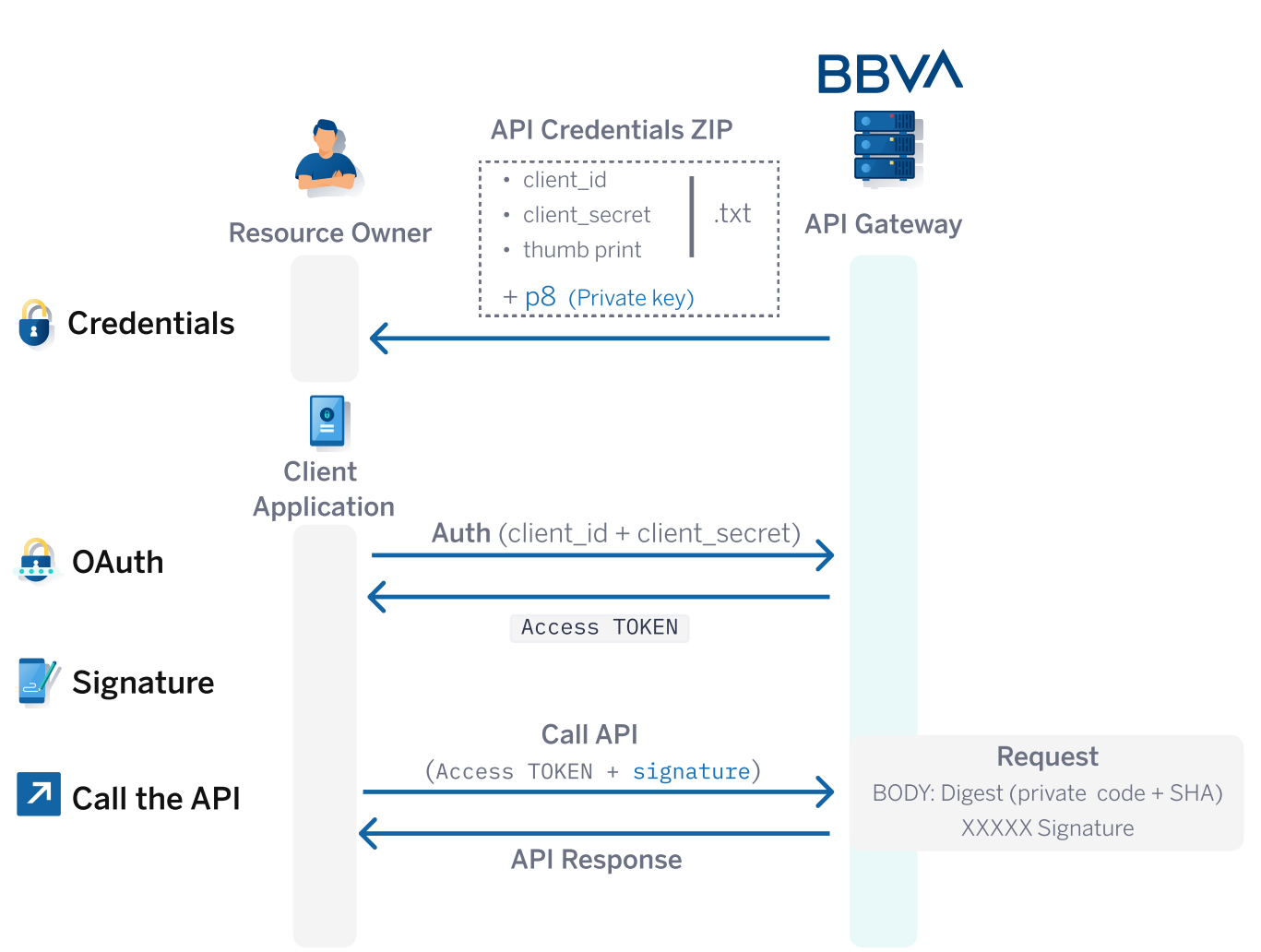
BBVA API Connect introduction

What is BBVA API Connect?

BBVA API Connect allows authorized BBVA clients or partners ("Third Party") to establish secure connections and communications with BBVA through APIs.

It combines OAuth 2.0 authorization - described at **RFC 6749** and digital signing with asymmetric keys.

This document describes the steps that the Third Party's technical team needs to call functional BBVA APIs.



Obtain credentials

Every API connection between BBVA and a Third Party must be previously configured.

BBVA performs the APP registration, both in SANDBOX and LIVE according to the terms agreed with the Third Party. BBVA will send the APP credentials with which the user can call the APIs. (They are sent by e-mail in a zip file with a password and the password to unlock the zip will be sent through another channel).

The set of credentials to received and required for the connection and further communications are:

- `client_id`
- `Client_secret`
- `thumb print`
- `private key` *

*For the `private key` there are two options:
1. BBVA generates a Private key for each APP, by including it in a .p8 file.
2. Third Party uses it's own Private key and gives BBVA the public key.

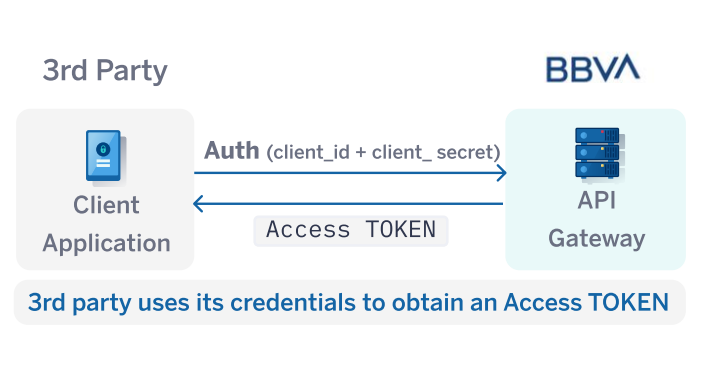
The `thumb print` is the fingerprint of a certificate (hash function), is the unique summary of a certificate in binary format, that can be used to verify that the attached certificate is the one that was originally sent by BBVA.

OAuth 2.0

BBVA combines OAuth 2.0 with digital signature. Those methods guarantee that the Third Party is properly authenticated as the integrity in the communications is secured.

Client credentials flow - 2 legged OAuth:

Use the `client_id` and `client_secret` provided by BBVA to obtain an `Access TOKEN`. This token is used in API communications and has an expiration time after which a new one must be obtained.



3rd party uses its credentials to obtain an Access TOKEN

The BBVA's Oauth endpoint is:

POST: ${host}/auth/oauth/v2/token

Please see the **host domains definition**** to understand the right configuration in your systems.

Example :

```
post 'https://apis.es.bbvaapimarket.com/auth/oauth/v2/token' \
```

Header

Include the following fields in the header:

Algorithms in "gzip" format.

NAME	VALUE	DESCRIPTION
Content-Type	String REQUIRED	Literal "application/x-www-form-urlencoded"
Accept-Encoding	String RECOMMENDED	Algorithms in "gzip" format. This headers involve that the response will come in gzip compress and will need to be decompressed.

Request Body

Parameters in Oauth 2.0 Client credentials flow API call **body**:

NAME	VALUE	DESCRIPTION
client_id	Provided by BBVA (Obtain credentials) REQUIRED	ID assigned to the APP.
client_secret	Provided by BBVA (Obtain credentials) REQUIRED	Secret assigned to the APP.
grant_type	"client_credentials" REQUIRED	Literal. Always the same for the Client Credentials Flow.

Response

HTTP Code API response:

- Code 200 - ok

NAME	VALUE	DESCRIPTION
access_token	String REQUIRED	`Access TOKEN` for the given token request.
token_type	"Bearer" REQUIRED	Literal. Always the same for the Client Credentials Flow.
expires_in	String RECOMMENDED	The expiry time, in seconds.
scope	"oob" OPTIONAL	Issued scope. "oob" is the default one.
resource	String OPTIONAL	List of hosts where the use of the token will be valid.

Example (fake credentials)

Request:

```
post 'https://apis.es.bbvaapimarket.com/auth/oauth/v2/token' \
--header 'Content-Type: application/x-www-form-urlencoded' \
--header 'Accept-Encoding: gzip' \
--data-urlencode 'grant_type=client_credentials' \
--data-urlencode 'client_id=10dc4cfebf38138750b9b381' \
--data-urlencode 'client_secret=bcd8121bcfdb4cga881ecafff2e0d514' \
```

Response:

```
{
 "access_token": "2bd83ef8-a63d-4cde-b007-1479164ee513-1733923303",
 "token_type": "Bearer",
 "expires_in": 1800,
 "scope": "oob"
 "resource": [
    "sbx.es.bbvaapimarket.com"
  ]
}
```

"expires_in": 1800 This value is an example, it indicates the expiration date of the token that has been created, after this date it will be necessary to create it again, the value given in the answer should be taken as a reference, not the one indicated in the example.

Important:

To optimize channel usage, keep in mind that **the access_token has the validity indicated in "expires-in"** (it may be approximately 30 minutes). Therefore, **do not request a new access_token before it expires**, to avoid overloading the channel.

- 4XX y 5XX codes - error

NAME	VALUE	DESCRIPTION
error	String REQUIRED	Error type.
error_description	String RECOMMENDED	Error description.

Examples:

Code 401 - Invalid credentials

```
{
 "error": "invalid_client",
 "error_description": "The given client credentials were not valid"
}
```

Code 400 - Missing or duplicated parameters (HTML)

```
{
 "error": "invalid_request",
 "error_description": "Missing or duplicate parameters"
}
```

Code 400 - Invalid grant_type

```
{
 "error": "unsupported_grant_type",
 "error_description": "The given grant_type is not supported"
}
```

Code 400 - Invalid grant_type for client

```
{
 "error": "invalid_request",
 "error_description": "The given grant_type is invalid for the client_id"
}
```

Code 500 - Unknown error

```
{
 "error": "invalid_request",
 "error_description": "The request failed due to some unknown reason"
}
```

HTTP signature

Each API request must be signed using the private key agreed between Third Party and BBVA.

Please go to **HTTP signature** to know the steps to be followed.

Call the APIs

The Third Party is ready to call BBVA APIs once it has the credentials for its APP, using OAuth 2.0.

Header for the API call:

NAME	VALUE	DESCRIPTION
Authorization	String REQUIRED	`Access TOKEN` obtained in OAuth 2.0.
Digest	String REQUIRED	Digest generated in HTTP signature.
Signature	String REQUIRED	Signature generated in HTTP signature.
Date	String REQUIRED	Value using **date format***.
Host	String REQUIRED	Host domain according to **host domain definition****.
Content-Type	String REQUIRED	Literal "application/json".
Accept-Encoding	String RECOMMENDED	Algorithms in "gzip" format. The response will come in gzip compress and will need to be decompressed.
x-usi	String OPTIONAL	Session ID for funnel management.

Now we are ready to call the BBVA API.

Example:

```
post /es/validations/v1/account-check

Headers:
  Host: sbx.es.bbvaapimarket.com
  Date: Mon, 8 Apr 2024 13:20:03 GMT
  Authorization: Bearer {{access-token}}
  Content-Type: application/json
  Accept-Encoding: gzip
  Digest:
SHA-512=Fqi4rr1sWWeMrUAgiHnncbjqmmPmCt2DWW67+/0InuWPKRfi0DFnonkz7Ok2J29ezp9iur6eHOMXUxU2R
+4BbA==
  Signature:expires="2524608000", algorithm="rsa-sha512", headers="(request-target) host
date digest", signature="Uxzm0I8ImtQtlUN0jYpMOvpBsd9UPgBYSgXTqvTZcsgGBzcYe/0jpWM/9hmYOv/S
70JwfVAbw7jwwrKaC6FPl095y4UbX3pHJHXK61pp6uoKe77zi4apb4wsqOKWSR2Tr4zHo4NyOVv6hSEPI9AhEpbRA
i7SnNW1JIkmHczw5aFH9xYzuvCx2A/SrhHFXjZixkjVgjIFjDghM2qzuFJU3dVFD6nPzrNoRf6YK3W3wLTtB/NQeO
ssyGR9R4Rtd2EXUiXTonvYQ/sTsGNxqIf+nU7MdpowrjO/YAJGKSEqmmjRIO6uPyJVdQkimyHwJ500ynyUbSaFaQy
8JoeWZjk14tuz4kqFa2ptlnPik1pirupm2gyXIMpKrZcuoco47W6YXEqy6nORWYL3TLunjeq7/so5XLItI7MucboP
4PRKwG5mLhtSqXY5JMB7aknN9c3XeYhB1BJ2t8EuTFL/f6m8pIEwwjgTLowIwSy7J0gQdDcRpxSDBwLfOeOvTpnTb
kmcj6ehejdi3C979aOVAOGUKXYedYhrh0JMiW+5F2LO14E+SSe2sygDLyI42FEffrdKsbbXHiGaWr5GEOSzbiBE2K
VxBToaUUhPStAOOJ1yMaqSFrbdsm9/0ed4OpFrVobryxN6aWrDen9WnKgBybmX3kTOqvC2cRgrp+QbYLXtpgA="

Body:{ "reference":
"TIC01820128202309280100504061057188000000000000000000000000000000000000" }
```

Response status 200 OK:

```
{
  "concepts": {
    "code": "CONFIRMED"
  }
}
```

Important:

The body we send in the request must be the same as the body signed in the toSign.txt of the HTTP signature.

The host we indicate in the call must be the same as the one included in the toSign.txt of the HTTP signature.

*Date format

In accordance to standard rfc1123 : "EEE, dd MMM yyyy HH:mm:ss Z", always in English. Where:
EEE = "Mon" /"Tue"/ "Wed" /"Thu"/ "Fri" /"Sat"/ "Sun"
MMM = "Jan" / "Feb" / "Mar" / "Apr"/ "May" / "Jun"/ "Jul" / "Aug"/ "Sep" / "Oct"/ "Nov" /"Dec"
Z= "UT" / "GMT"/ "EST" / "EDT"/ "CST" / "CDT"/ "MST" / "MDT"/ "PST" / "PDT"/ 1ALPHA/ (("+" / "-") 4DIGIT)

Example: "Mon, 08 Apr 2024 13:20:03 GMT"

**Host domain definition

For SANDBOX and LIVE the domain will be:

https://sbx.COUNTRYCODE. bbvaapimarket.com
https://apis.COUNTRYCODE. bbvaapimarket.com

Where the COUNTRYCODE is:

COUNTRY	COUNTRYCODE	EXAMPLE
Argentina	ar	https://apis.ar.bbvaapimarket.com
Colombia	co	https://apis.co.bbvaapimarket.com
España	es	https://apis.es.bbvaapimarket.com
Mexico	mx	https://apis.mx.bbvaapimarket.com
Perú	pe	https://apis.pe.bbvaapimarket.com

Only the PIVOT global APIs shall not carry a COUNTRY CODE:

https://sbx. bbvaapimarket.com
https://apis. bbvaapimarket.com

Do not hesitate to consult your BBVA Technical Account Manager if you do not know your API host.